

מהו סייבר?



מרחב הסייבר: עולם ללא גבולות

מרחב הסייבר מורכב ממערכות מידע ורשתות המקושרות ביניהן, ואינו מוגבל לגיאוגרפיה פיזית. זהו עולם דיגיטלי שבו פעולות והעברת נתונים מתבצעות במהירות שיא מקצה אחד של העולם לקצהו השני.

עלות נמוכה

א-סימטריה: עלות התקיפה נמוכה מאוד ביחס לנזק הפוטנציאלי

מהירות וטשטוש גבולות

העברת נתונים מתבצעת במהירות שיא ללא תלות במרחק פיזי

היפר-קישוריות

חיבור גובר של מכשירים יום-יומיים מרחיב את משטח התקיפה

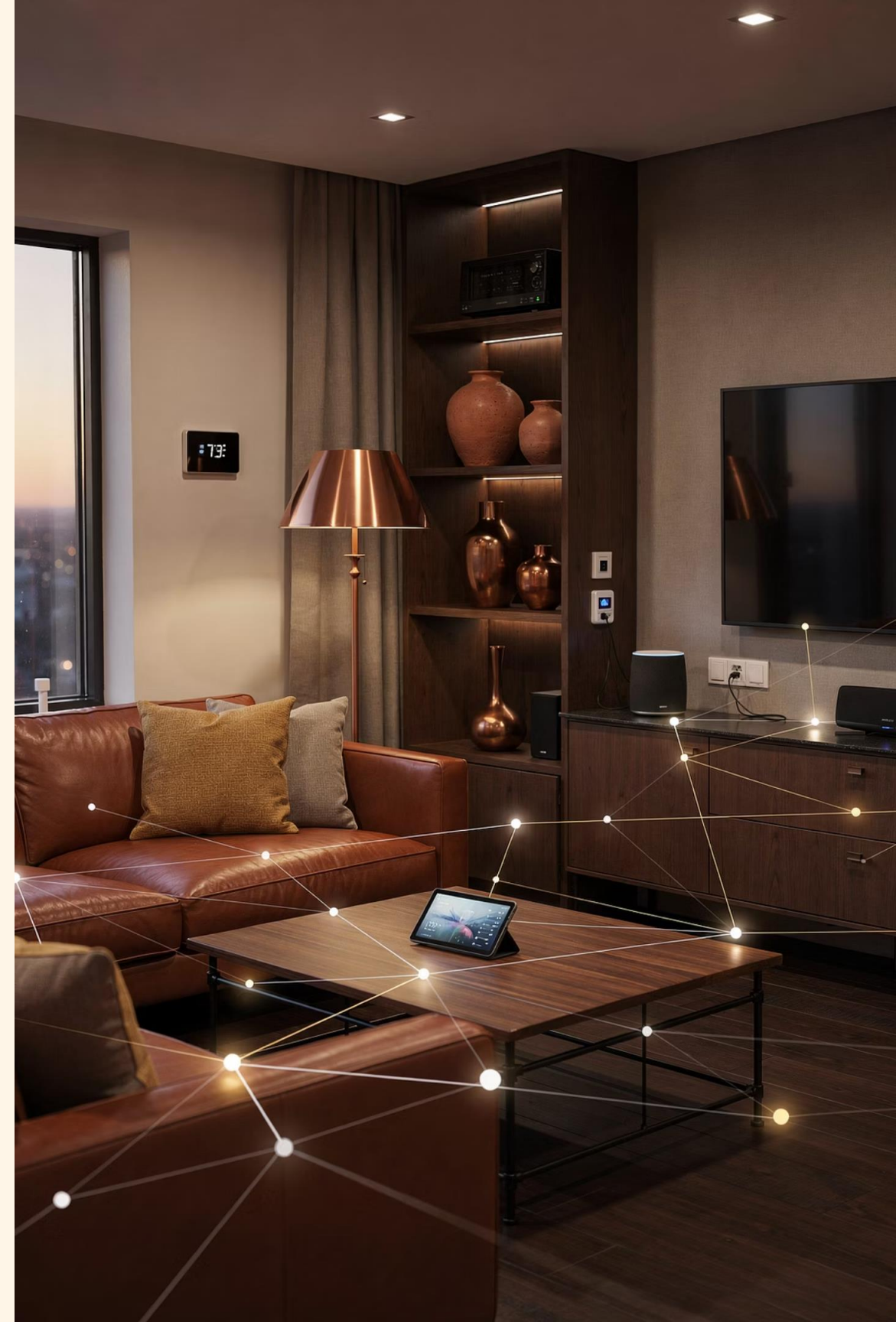
אנונימיות

קושי רב בזיהוי מהיר של תוקפים עקב טשטוש עקבות דיגיטליים

האינטרנט: הזדמנות ואיום

חיבור גובר של מכשירים יום-יומיים לרשת מרחיב משמעותית את משטח התקיפה. מצלמות אבטחה, מקררים חכמים, שעונים ורכבים מקושרים - כולם יכולים להפוך לשער כניסה לתוקפים.

הנוזקות יכולות להתפשט במהירות בין מכשירים מקושרים וליצור נזק רחב היקף, לעיתים מבלי שבעלי המכשירים בכלל יודעים על כך.



שבעת שלבי המתקפה

01	איסוף מודיעין	חקר יעד התקיפה לאיתור חולשות טכנולוגיות ואנושיות
02	חימוש	הכנת הנוזקה (Malware) המותאמת לחולשה שאותרה
03	הפצה	החדרת הנוזקה דרך פשינג USB, או התקני IoT
04	ניצול	הפעלת הקוד המשיג הרשאות גישה ראשוניות
05	התקנה	התבססות הנוזקה בתוך המערכת והורדת רכיבים נוספים
06	שליטה ובקרה	יצירת "דלת אחורית" לשליטה מרחוק של התוקף
07	פעולות להשגת היעד גניבת מידע, הצפנתו כופרה, או הרס	

שלב: 1-2 מודיעין וחימוש

חימוש

התוקף מכין את "הנוזקה שתנצל את החולשות שאותרו.

- שימוש בנוזקה קיימת מה Darknet-
- התאמת נוזקה קיימת לצרכים ספציפיים
- כתיבת נוזקה חדשה מאפס

זמן ההכנה: מימים בודדים ועד חודשים ושנים.

איסוף מודיעין

התוקף בוחן את יעדי התקיפה ואוסף מידע על סוג הארגון, אופן הפעולה, פלטפורמות טכנולוגיות ומערכות הפעלה.

דוגמה: זיהוי שהארגון משתמש בגרסת תוכנה ישנה ללא עדכוני אבטחה, או איתור עובד שנוטה להוריד קבצים ממקורות לא מזהים.



שלב 3-4: הפצה וניצול

הפצה: שליחת הנוזקה אל מחשב היעד דרך ערוצים מגוונים - דואר אלקטרוני פשינג, אתרי אינטרנט נגועים, או רכיבי IoT כמו מדפסת מקושרת, טלפון חכם אישי, או שעון חכם.

ניצול: רגע הפריצה בפועל. קטע הקוד הייעודי (Exploit) מופעל במחשב היעד ומנצל את החולשה שהתגלתה, ומספק לתוקף הרשאות גישה ראשוניות ובלתי מורשות למערכת.

שלב :התקנה, שליטה ופעולה

התקנה

1

הנוזקה ממסדת את מעמדה ומתקינה את עצמה באופן נסתר . מרחיבה לעצמה את ההרשאות ברשת.

שליטה ובקרה (C2)

2

התוקף מבסס ערוץ תקשורת חשאי ושותל "דלת אחורית" המאפשרת לו לחדור מתי שירצה ,תוך עקיפת חומות האש ומערכות ניטור.

פעולות להשגת מטרה

3

מחיקת קבצים ,כופרה ,הריסה ,גניבת מידע ,התפשטות רוחבית למערכות נוספות ,או התקנת תוכנות ריגול ארוכות טווח.

קריסת רשת החשמל באוקראינה

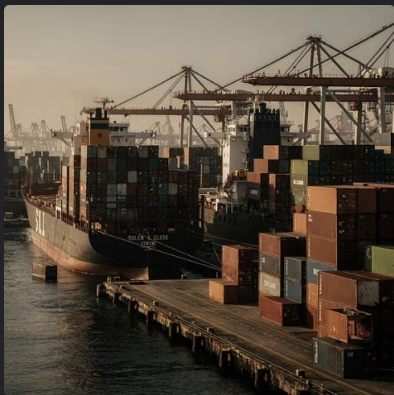
בחג המולד 2015, רוסיה הצליחה לגרום לקריסת אספקת החשמל בבתים רבים באוקראינה באמצעות מתקפת סייבר. המתקפה יוחסה למאבק רוסי נגד סירובה של אוקראינה להשלים עם הפלישה לחצי האי קרים.

המתקפה הדגימה כיצד תקיפת תשתיות קריטיות יכולה לפגוע באזרחים בשיאו של החורף ולהחליש את חוסנה של מדינה.



נוזקות כופר NotPetya ו-WannaCry-

בשנת 2017 התרחשו שתי מתקפות גלובליות שניצלו חולשה מוכרת במערכות הפעלה שלא עודכנו. המתקפות הצפינו מידע במחשבים ברחבי העולם ודרשו כופר לשחרורו.



שיתוק עולמי: NotPetya

המתקפה שיתקה את חברת הספנות הענקית, Maersk, יצרה פקקי ענק בנמלים ברחבי העולם וגררה הפסדים כבדים. הנזק הכלכלי הגיע למאות מיליוני דולרים.



התפשטות מהירה: WannaCry

הנוזקה התפשטה במהירות בין מחשבים מקושרים, פגעה בבתי חולים, עסקים וארגונים ממשלתיים. המתקפה הדגישה את החשיבות של עדכוני אבטחה.

כאשר המצלמה שלך הופכת לנשק

מתקפת Mirai (2016) ניצלה סיסמאות ברירת מחדל של יצרנים במאות אלפי מצלמות ונתבים ביתיים. המכשירים הפכו ל"צבא" בוטים וביצעו מתקפת מניעת שירות (DDoS) שהפילה אתרים מרכזיים כמו נטפליקס וטוויטר.

הלקח המרכזי

בעלי המכשירים לא ידעו שהמכשירים שלהם משתתפים במתקפה. זהו דוגמה מושלמת לניצול ההיפר-קישוריות ולחשיבות אבטחת מכשירי IoT.



מתקפות על מערכות המים בישראל

בשנת 2013 דווח על ניסיון סורי לתקוף את מערכת המים בעיר חיפה .

באפריל 2020 התרחשה מתקפה משמעותית נוספת
נגד מערכות ה-SCADA של מתקני מים השייכים לתאגידי מים וביוב בישראל.

המתקפה של 2020

המתקפה יוחסה לאיראן ומטרתה הייתה לפגוע באספקת
המים לאזרחים. לשנות את הויסות האלכלור וחומרים כימים .

זהו דוגמה לניסיון לפגוע בתשתית קריטית שיכולה להשפיע
ישירות על חיי היומיום של מיליוני אזרחים.





עקרונות היסוד : למניעה ע"פ מודל CIA

כל פעולת מניעת סייבר נמדדת לפי שלושה צירים:

1

Confidentiality — סודיות

מניעת חשיפת מידע לגורם לא מורשה.

2

Integrity — אמינות

הבטחה שהמידע לא שונה או "זוהם" בדרך.

3

Availability — זמינות

הבטחה שהמערכת נגישה למשתמשים בזמן אמת.

מדידת אבטחת מידע ROI -

מהו ROI?

הוא מדד (Return on Investment) שמעריך את התשואה או הרווח שהושג כתוצאה מהשקעה מסוימת ביחס לעלות שלה.

בעברית: החזר על ההשקעה -מדד שמראה עד כמה השקעה מסוימת הייתה כדאית.

מדידה באבטחת מידע

מדידת אבטחת מידע נעשית באמצעות ROI, המשווה את עלויות ההשקעה לעלויות שנחסכו. בנוסף, משתמשים במדדים כמו:

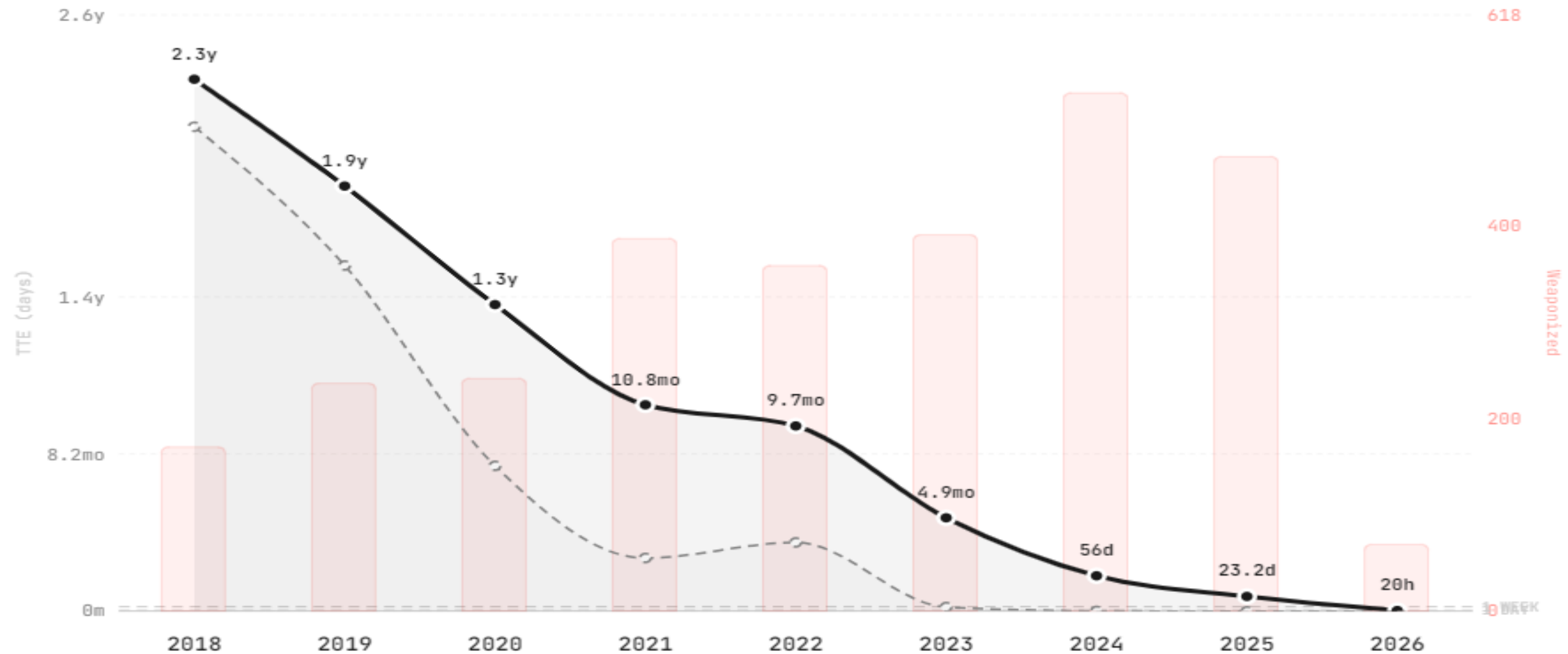
- זמן תגובה לאיומים
- תאימות לרגולציות
- שמירה על המשכיות עסקית



From Vulnerability to Exploitation

TTE (Time-to-Exploit) measures the gap between CVE disclosure and confirmed exploitation

— Mean TTE (10% trimmed, days) --- Median TTE (days) ■ Weaponized Exploits (count)



Based on 3,529 CVE-exploit pairs from trusted sources (CISA KEV, VulnCheck KEV & XDB)

● zerodayclock.com

Time-to-Exploit Milestones

When mean time-to-exploit crosses each threshold

תוך כמה זמן יקח לפרוץ לחברה בממוצע , מיום
התגלות הכשל.

1

Year

REACHED

~2021

1

Month

REACHED

~2025

1

Week

REACHED

~2026

1

Day

REACHED

~2026

1

Hour

PROJECTED

~2026

1

Minute

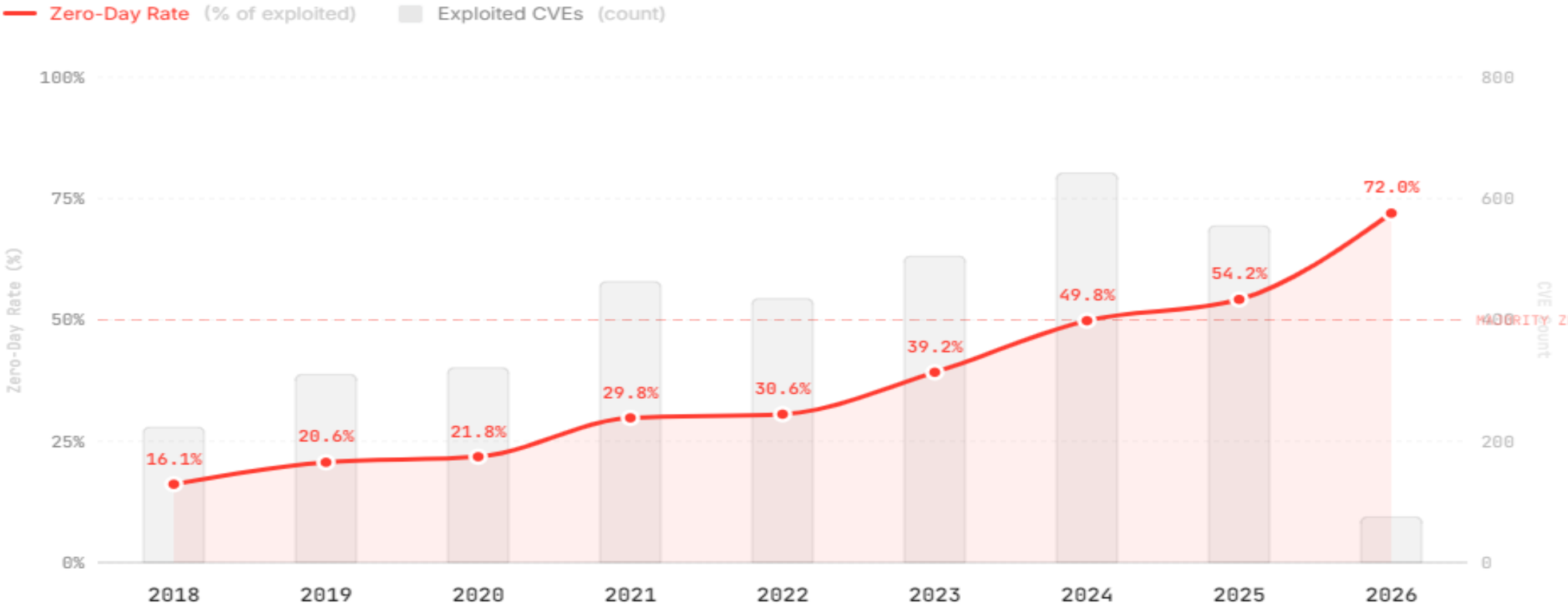
PROJECTED

~2028

Zero-Day Rate

הסתברות אפשרת פריצה תוך יום , מיום התגלות הכשל

Percentage of exploited CVEs where exploitation occurred before or on the day of disclosure (TTE ≤ 0)



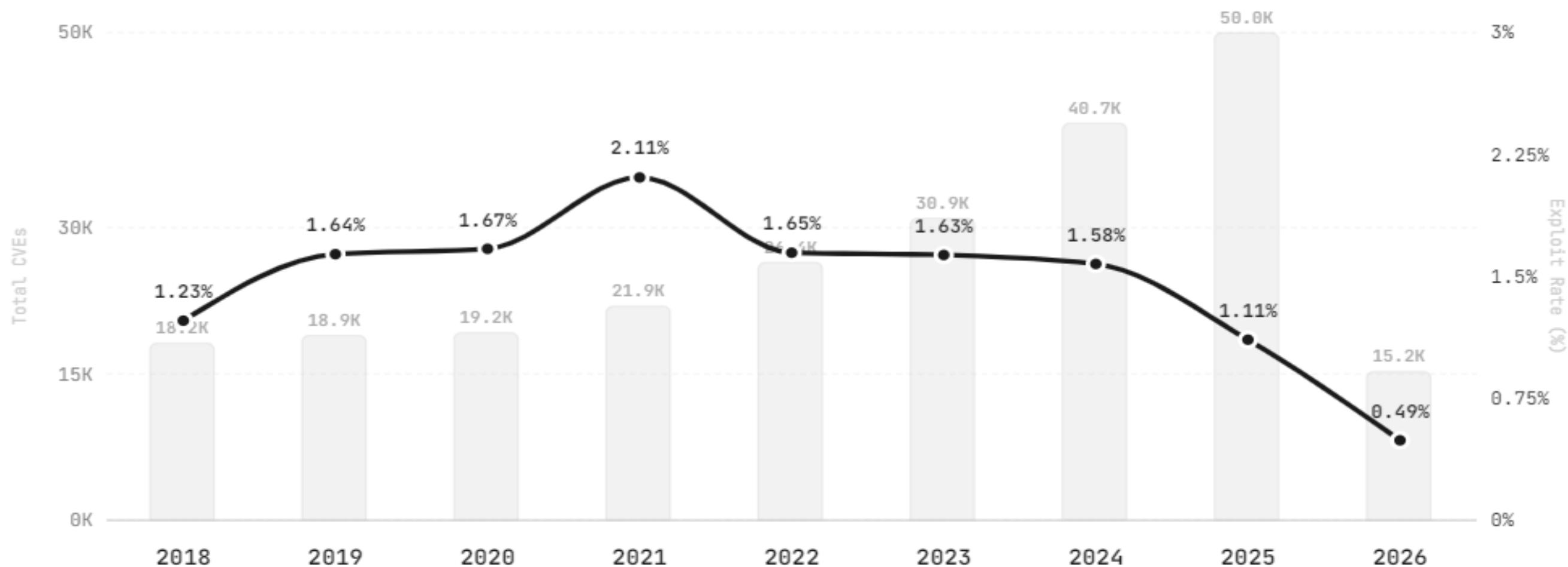
72.0% of exploited CVEs in 2026 are zero-days, up from 16.1% in 2018

Exploit Rate

Percentage of all published CVEs that are confirmed exploited in the wild, versus total CVE volume

— Exploit Rate (% of all CVEs) ■ Total CVEs Published (count)

כמות החולשות שמתגלות בתוכנות בפריצה

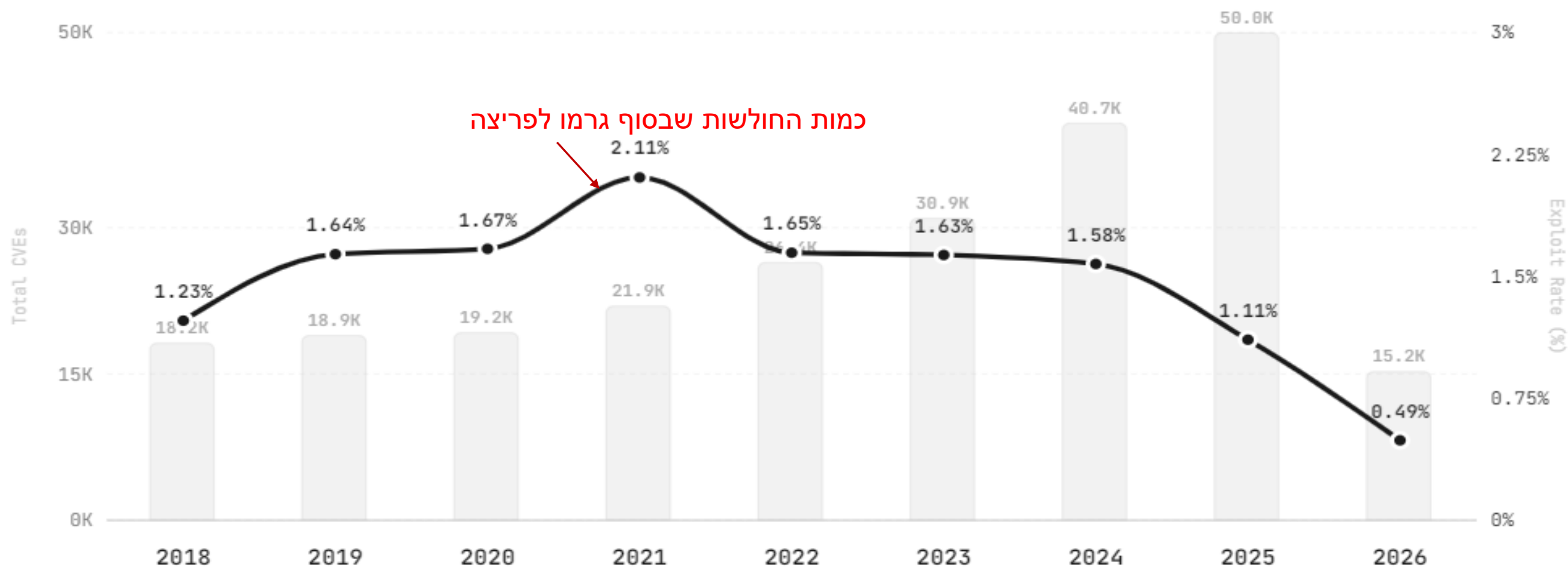


15,240 CVEs published in 2026, 75 exploited (0.49%). CVE volume grew -70% year-over-year

Exploit Rate

Percentage of all published CVEs that are confirmed exploited in the wild, versus total CVE volume

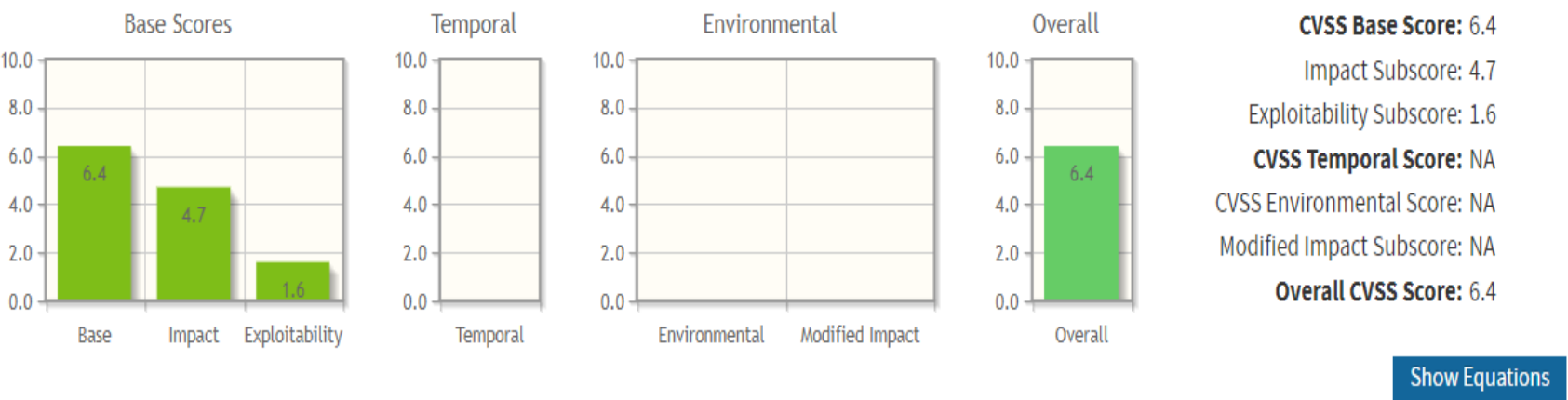
— Exploit Rate (% of all CVEs) ■ Total CVEs Published (count)



15,240 CVEs published in 2026, 75 exploited (0.49%). CVE volume grew -70% year-over-year

Common Vulnerability Scoring System Calculator

This page shows the components of a [CVSS](#) assessment and allows you to refine the resulting CVSS score with additional or different metric values. Please read the [CVSS standards guide](#) to fully understand how to assess vulnerabilities using CVSS and to interpret the resulting scores. The scores are computed in sequence such that the Base Score is used to calculate the Temporal Score and the Temporal Score is used to calculate the Environmental Score.



CVSS 3.1 Vector
[AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:H](#)

Base Score Metrics

Exploitability Metrics

Attack Vector (AV)*

Network (AV:N) | Adjacent Network (AV:A) | Local (AV:L) | Physical (AV:P)

Attack Complexity (AC)* כמה "מאמץ" או תנאים מיוחדים נדרשים כדי שהתקיפה תצליח

Low (AC:L) | High (AC:H)

Privileges Required (PR)* הרשאות נדרשות

None (PR:N) | Low (PR:L) | High (PR:H)

User Interaction (UI)* האם התוקף צריך "עזרה" מהקורבן

None (UI:N) | Required (UI:R)

האם התוקף מ"קופסה" אחת ל"קופסה" אחרת. Scope (S)*

Unchanged (S:U) | Changed (S:C)

Impact Metrics

Confidentiality Impact (C)* סודיות

None (C:N) | Low (C:L) | High (C:H)

Integrity Impact (I)* שלמות המידע

None (I:N) | Low (I:L) | High (I:H)

Availability Impact (A)* זמינות

None (A:N) | Low (A:L) | High (A:H)

* - All base metrics are required to generate a base score.



מה רושמים ואיפה? הסבר על ה-Base Score

המחשבון מחולק לקבוצות Base Score Metrics -אלו המדדים שקובעים את חומרת החולשה כשלעצמה.

ב. מה גודל הנזק (Impact Metrics)?

כאן משתמשים במודל ה CIA-הקלאסי:

Confidentiality (C)

האם נגנב או יכול להגנב מידע?

Integrity (I)

האם התוקף שינה או יכול לשנות נתונים? אמינות)

Availability (A)

האם האתר קרס זמינות



האפשרויות (None: אין נזק) Low, (נזק חלקי) High, (נזק מלא).

א. איך פורצים (Exploitability Metrics)?

Attack Vector (AV): מאיפה התוקף מגיע?

- Network: (הכי) מהאינטרנט (מסוכן).
- Physical: הוא חייב לגעת במכשיר בידיים.

Attack Complexity (AC): כמה קל לפרוץ?

- Low: כל אחד עם מדריך יוטיוב יכול.
- High: צריך תנאים נדירים או מיומנות מטרפת.

Privileges Required (PR): מה צריך להיות לתוקף לפני שהוא מתחיל?

- None: (הכי גרוע) הוא פשוט נכנס.
- High: הוא כבר חייב להיות מנהל מערכת.

User Interaction (UI): האם הקורבן צריך לעשות משהו?

- None: (הכי) הפריצה שקופה (מסוכן).
- Required: הקורבן חייב ללחוץ על לינק או להוריד קובץ.

דוגמה מעשית לפריצה של חברת ביטוח הכשרה

01	02	03
AV (מאיפה?)	AC (כמה קשה?)	PR (הרשאות?)
נבחר (Network) כי הוא פורץ מרחוק.	נבחר Low כי יש לו כלי אוטומטי.	נבחר (None) הוא לא צריך משתמש כדי להתחיל
04	05	06
UI (אינטראקציה?)	C (סודיות?)	I (אמינות?)
נבחר (Non) חייב ללחוץ על קובץ	נבחר High כי הוא קורא את כל המיילים(וגנב מידע).	נבחר (Low)הוא רק קורא, לא משנה מיילים
07		
A (זמינות?)	נבחר Noneהכול ממשיך לעבוד כרגיל	



התוצאה: הציון הסופי מחולק לשנים .



הטיפ למרצה: "הווקטור"

מתחת למחשבון מופיעה שורה שנראית כמו קוד, למשל:

`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:L/A:N`

למה זה שימושי?

אם הם שולחים את השורה הזו לאיש אבטחה אחר, הוא יכול להזין אותה אצלו ולראות בדיוק מה הגדרתם.

מה זה אומר?

ה"תעודת זהות" של החולשה.

ביאור 28 מגזרי פעילות פיקוחיים (המשך)

מידע על מגזרי פעילות פיקוחיים

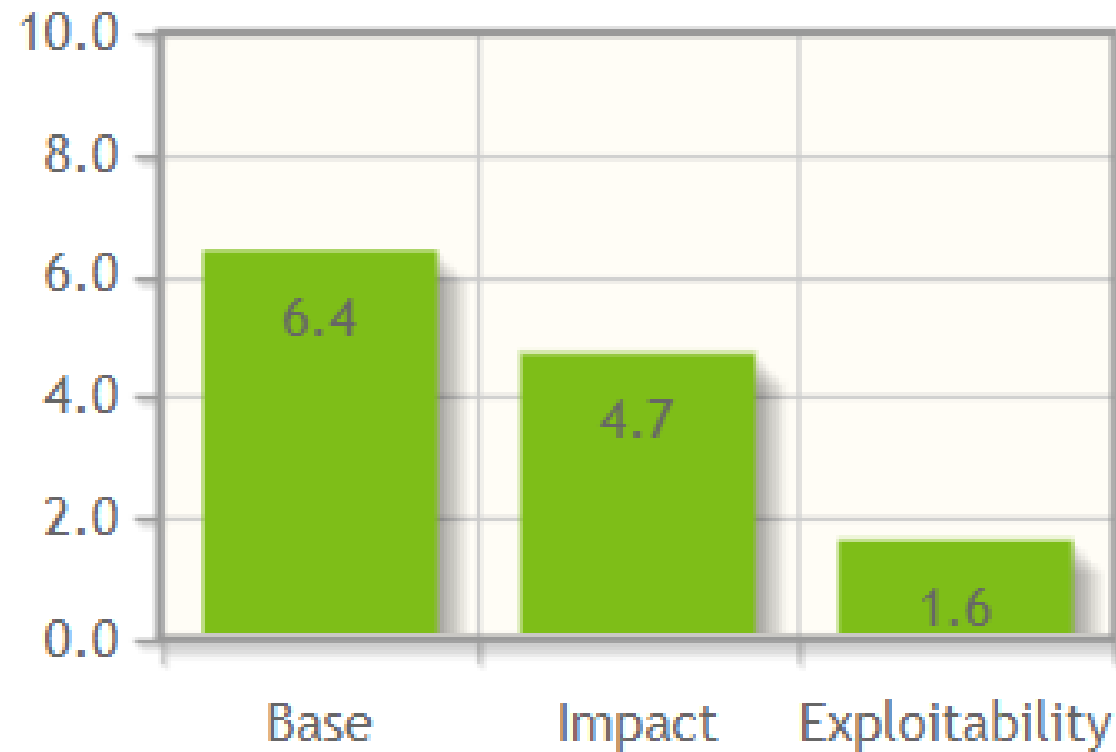
לשנה שהסתיימה ביום 31 בדצמבר 2025

פעילות ישראל

מסקי בית	בנקאות פרטית	עסקים קטנים וזעירים	עסקים בינוניים	עסקים גדולים	
9,946	37	4,478	3,210	8,319	הכנסות ריבית מחיצוניים
(3,164)	(1,492)	(2,302)	(1,049)	(3,410)	הוצאות ריבית לחיצוניים
					הכנסות ריבית, נטו:
6,782	(1,455)	2,176	2,161	4,909	מחיצוניים
347	1,888	2,004	(550)	(1,471)	בינמגזרי
7,129	433	4,180	1,611	3,438	סך הכנסות ריבית, נטו
					הכנסות שאינן מריבית:
(297)	-	11	(31)	28	הכנסות (הוצאות) מימון שאינן מריבית
1,418	191	1,171	393	822	עמלות והכנסות אחרות
1,121	191	1,182	362	850	סך הכנסות שאינן מריבית
8,250	624	5,362	1,973	4,288	סך הכנסות
					הוצאות (הכנסות) בגין הפסדי אשראי
601	-	517	121	(38)	הוצאות תפעוליות ואחרות:
3,934	218	2,032	391	652	לחיצוניים
-	-	-	-	-	בינמגזרי
3,934	218	2,032	391	652	סך הוצאות תפעוליות ואחרות
					רווח (הפסד) לפני מסים
3,715	406	2,813	1,461	3,674	הפרשה למסים (הטבת מס) על הרווח (הפסד)
1,365	149	1,033	548	1,381	רווח (הפסד) לאחר מסים
2,350	257	1,780	913	2,293	חלקו של הבנק ברווחים של חברות כלולות
-	-	-	-	-	רווח (הפסד) נקי לפני ייחוס לבעלי זכויות שאינן מקנות שליטה
2,350	257	1,780	913	2,293	הפסד (רווח) המיוחס לבעלי זכויות שאינן מקנות שליטה
-	-	-	-	-	רווח (הפסד) נקי המיוחס לבעלי מניות הבנק
2,350	257	1,780	913	2,293	

נטישה כ-0.1% לקוחות

Base Scores



Impact ציון: 4.7 – "עוצמת המכה" זהו מדד התוצאה. הוא עונה על השאלה: אם התוקף

הצליח לפרוץ, מה הנזק שנגרם לנכסים שלנו?"

הוא מבוסס על שלושת עמודי התווך של אבטחת מידע (CIA):

סודיות (Confidentiality) האם נגנב מידע רגיש?

אמינות (Integrity) האם התוקף שינה או מחק נתונים?

זמינות (Availability) האם המערכת קרסה או הפסיקה לעבוד?

Exploitability ציון: 1.6 – "רמת הקושי"

זהו מדד המאמץ. הוא עונה על השאלה: "כמה קל או קשה לתוקף לנצל את החולשה הזו?"

הוא מורכב מארבעה תנאים שחייבים להתקיים כדי שהפריצה תצליח:

• **Attack Vector:** האם הוא פורץ מהאינטרנט או שצריך להיות פיזית ליד המחשב?

• **Attack Complexity:** האם הפריצה פשוטה או שהיא דורשת ידע נדיר ותנאים מיוחדים?

• **Privileges Required:** האם הוא צריך להיות "מנהל מערכת" כדי להתחיל, או שהוא יכול להיות אורח

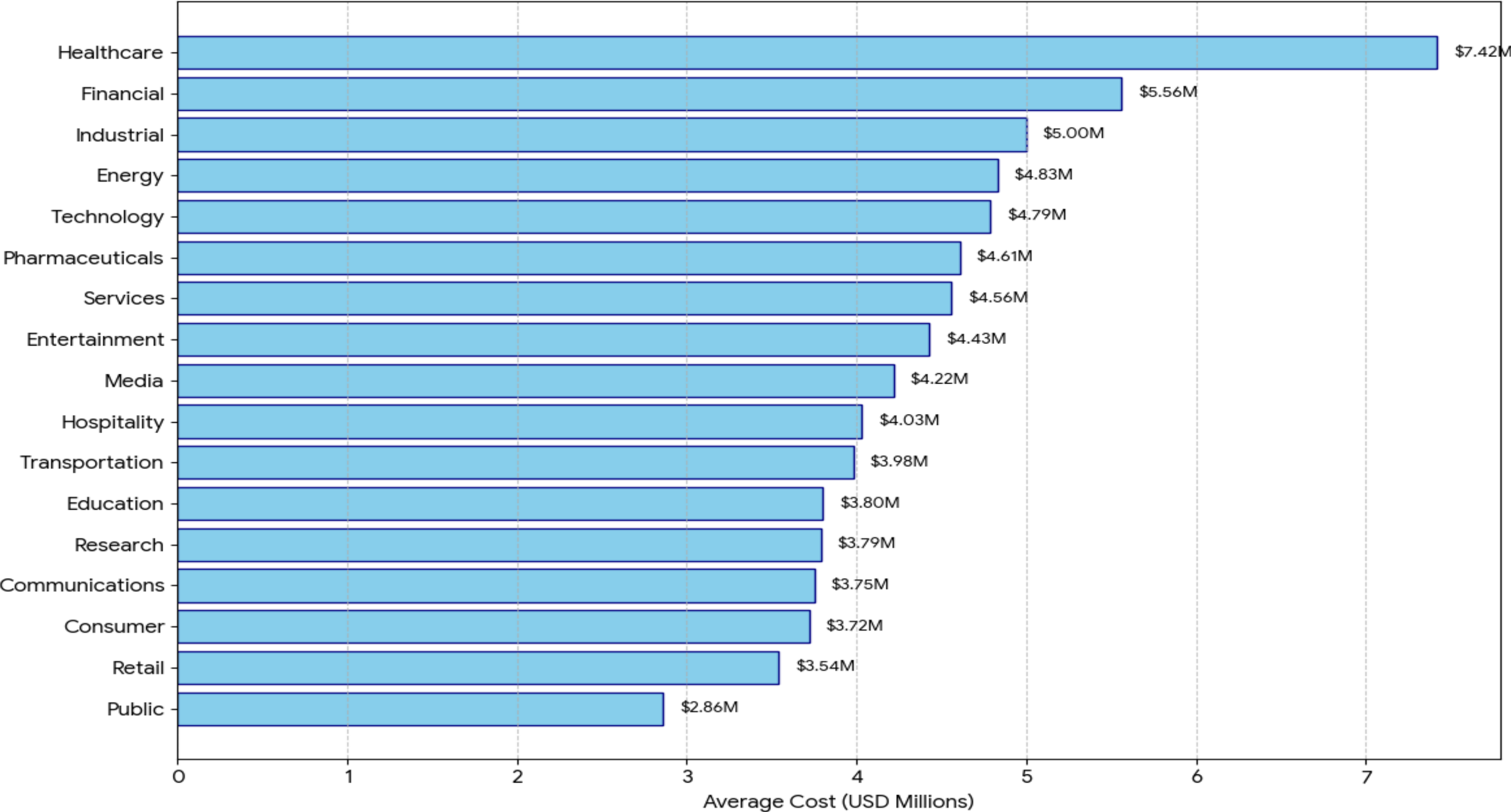
אנונימי?

• **User Interaction:** האם התוקף חייב שהמשתמש ילחץ על משהו (כמו לינק חשוד)?

$$\text{Total Cost} = \text{Lost per} * \text{Loss Reputation Factor} * \frac{\text{Impact}}{10} * \frac{\text{Exploitability}}{10}$$

$$1.5 \text{ מיליון} = 20,500 * 0.1\% * \frac{4.7}{10} * \frac{1.6}{10}$$

Average Cost of a Data Breach by Sector



ניהול סיכונים

סיכון, איום ופגיעות



סיכון — Risk

הפוטנציאל לאובדן או נזק כאשר איום מנצל פגיעות. **סיכון דורש אי-ודאות** — גורל ודאי אינו סיכון.



פגיעות — Vulnerability

חולשה שניתן לנצל על ידי גורם איום לביצוע פעולות בלתי מורשות כנגד נכס. מנוהלת דרך מאגר +218,264 CVE רשומות.



איום — Threat

סכנה אפשרית שעלולה לנצל פגיעות ולפגוע בנכס — **Threat Agent**. ישות שעלולה לפעול על פגיעות.



נכס — Asset

משאב בעל ערך כלכלי. **Asset Value = Hacking Value**. נכסים מוחשיים: שרתים, מחשבים. בלתי מוחשיים: פטנטים, ידע.

אפשרויות ניהול סיכונים

Avoidance — הימנעות

הפסקת הפעילות המסוכנת לחלוטין.

Acceptance — קבלה

קבלת הסיכון כפי שהוא, ללא פעולה.

Mitigation — צמצום

יישום בקורות להפחתת הסיכון.

Transfer/Sharing — העברה

העברת הסיכון לצד שלישי ביטוח, ספק.



Avolance



Acceptance

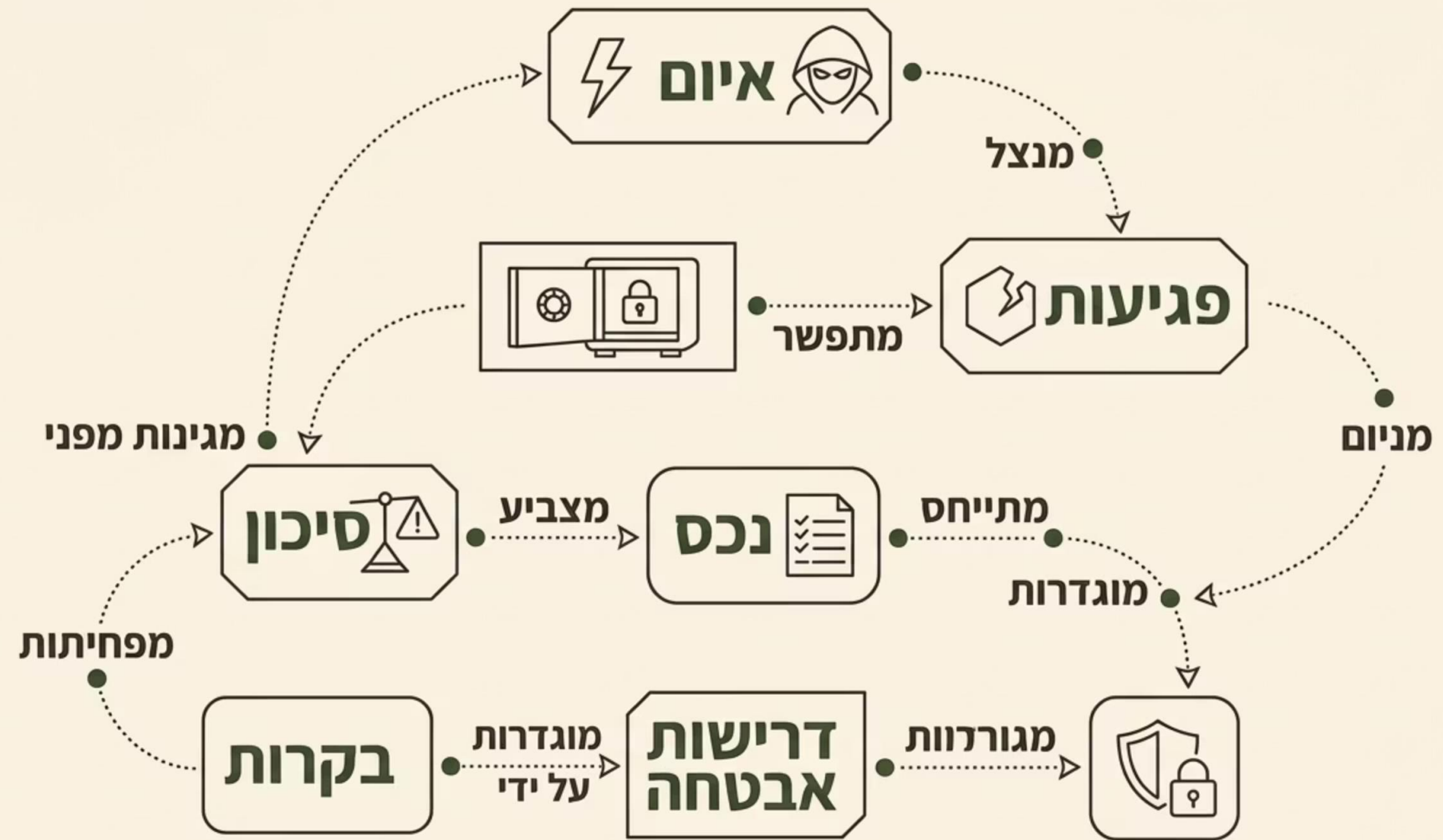


Mitigation



Transfer

קשרי הגומלין — סיכום



Governance vs. Management

Governance — ממשל

מטרה: קביעת יעדים ואסטרטגיה.

"Do the right thing" — לעשות את הדבר הנכון.

רמת הדירקטוריון והנהלה בכירה. מגדיר מה צריך להיעשות.

Management — ניהול

מטרה: תכנון, בנייה, ביצוע וניטור פעילויות להשגת יעדים.

"Do the thing right" — לעשות את הדבר כראוי.

רמת המנהלים והצוותים. מגדיר איך מבצעים.

סוגי בקורות אבטחה

בקורות אבטחה הן אמצעי הגנה או נגד-אמצעים למניעה, זיהוי, תיקון או צמצום סיכוני אבטחה. מסגרות עיקריות: **ISO27001, COBIT, NIST SP800-53**.



Administrative (Managerial)

חלות על תהליכים והתנהגויות. דוגמאות :
מדיניות, נהלים, פיתוח עובדים, דיווח ציות.



Technical (Logical)

חלות על מערכות מידע, תוכנה ורשתות .
דוגמאות :חומות אש, IDS, סיסמאות, אנטי-
וירוס.



Physical (Operational)

חלות על מתקנים ואזורים. דוגמאות :מנעולים ,
גדרות, מצלמות, CCTV,מכשירי מניעת גישה.

קטגוריות בקרות אבטחה

Preventative

בקרות האוסרות פעילות מסוימת.

Corrective

בקרות המגיבות למצב לצורך תיקון או שחזור.

Detective

בקרות המזהות פעילות עוינת או חריגה.

Compensating

בקרות המפחיתות השפעות אובדן בקרות ראשיות.

Deterrent

בקרות המפחיתות את הסבירות שמישהו יבחר לבצע פעילות מסוימת.

Directive

בקרות המטילות מנדטים ודרישות.

Recovery

בקרות לשחזור פעולות למצב תקין לאחר אירוע אבטחה.



בקרות רבות יכולות להשתייך למספר קטגוריות. נעדיף בקרות המממשות מספר סוגים בו-זמנית.

הגנה בעומק — Defense in Depth

